Rozpoznávanie škodlivých programov kombináciou dvoch pohľadov

Zhrnutie experimentov k dizertačnej práci · Dušan Čatloch · 7. 11. 2026

Najdôležitejšie v skratke

- **Takmer všetko potrebné sa dá zistiť zo súboru bez jeho spustenia.** Údaje o tom, čo program robí pri spustení, pridávajú málo – a pri úplne nových druhoch malvéru nepomáhajú vôbec.
- **Viacstupňový systém (kaskáda) neodhalí viac malvéru, ale robí menej planých poplachov** (asi o pätinu) a **spúšťa iba asi 22 % súborov** namiesto všetkých – teda šetrí najdrahší krok.
- **Pri nových druhoch malvéru je hlavný problém zle nastavená „citlivosť“ modelu, nie nedostatok informácií.** Dá sa z veľkej časti napraviť, ak sa model doladí na čerstvých neškodných programoch.
- **Tézy:** dve sa potvrdili, jedna čiastočne, jedna nie – tá má jasné vysvetlenie a navrhujeme, ako ju preformulovať.
- Výsledky sme overili aj štatisticky – nie sú dielom náhody.

1. O čom je výskum

Antivírus môže posúdiť súbor dvoma spôsobmi. **Statická analýza** skúma súbor bez spustenia (jeho štruktúru, použité knižnice, texty v ňom) – je rýchla. **Dynamická analýza** súbor bezpečne spustí v napodobenine Windows (emulátore) a zaznamená, čo program robí – je pomalá (až desiatky sekúnd na súbor). Otázka práce: **oplatí sa ich kombinovať**, a dá sa to urobiť tak, aby sa pomalý krok robil iba vtedy, keď je naozaj potrebný?

Pojmy, ktoré sa v texte opakujú

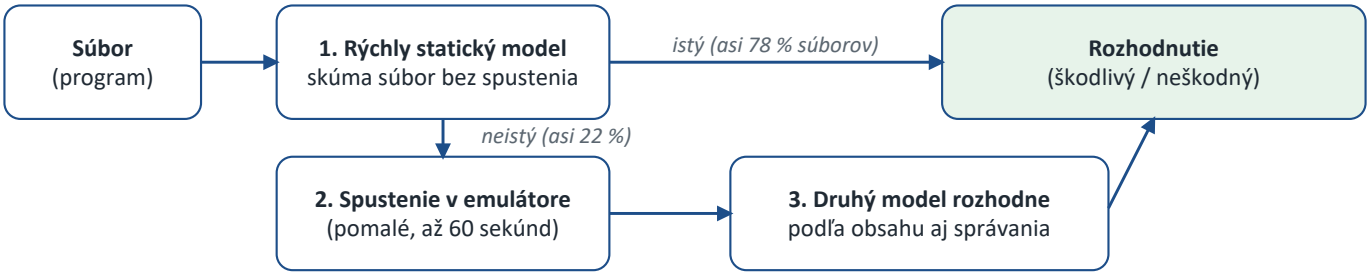
Pojem	Čo znamená
Model	program, ktorý sa z príkladov naučil rozlišovať škodlivé a neškodné súbory a každému súboru priradí skóre
Statický / dynamický / hybridný model	rozhoduje podľa obsahu súboru / podľa správania pri spustení / podľa oboch naraz
Kaskáda	niekoľko modelov za sebou: lacný model rozhodne jasné prípady, drahší krok sa použije iba pri sporných (obrázok v časti 2)
Zachytený malvér	koľko percent škodlivých súborov model správne odhalí (98 % = 98 zo 100)
Planý (falošný) poplach	neškodný program označený ako škodlivý; uvádzame ich počet na 10 000 neškodných programov
Nová rodina malvéru	druh malvéru, ktorý model pri učení nikdy nevidel – napodobňuje nový, doteraz neznámy útok
Prah (citlivosť)	hranica skóre, od ktorej model súbor označí ako škodlivý; nastavili sme ho tak, aby na januárových kontrolných dátach bolo najviac 1 % planých poplachov
Destilácia, „študent“	malý rýchly model („študent“) sa učí napodobniť veľký pomalý model („učiteľa“)
Percentuálny bod (p. b.)	rozdiel dvoch percent: z 79 % na 83 % je to +4 p. b.

2. Ako sme postupovali

Použili sme verejnú databázu **Quo Vadis** (2022): asi 92 000 programov – neškodné a 7 druhov („rodín“) malvéru, napr. ransomvér (zašifruje súbory a žiada výkupné), trójske kone, keyloggery. Ku každému súboru sú k dispozícii údaje z oboch analýz. Modely sa učili na súboroch z **januára 2022** a skúšali sa na súboroch z **apríla 2022**, teda na novších, ako aké videli – tak ako v skutočnom nasadení. Pravidlá hodnotenia sme si vždy zapísali vopred a podľa výsledkov ich nemenili.

Krok	Čo sme robili
V1	Porovnali sme statické, dynamické a hybridné modely rôznych typov (od jednoduchých po neurónové siete). Najlepšie vyšiel vo všetkých troch skupinách **LightGBM** (rýchla metóda rozhodovacích stromov). Vyskúšali sme **kaskádu A**: dvaja malí „študenti“ (statický a dynamický) rozhodnú a ak sa nezhodnú, rozhodne veľký hybridný model.
V2	**Test na nových rodinách:** 7-krát sme jednu rodinu malvéru úplne vynechali z učenia a zisťovali, koľko z nej model rozpozná. Pridali sme **kaskádu B** (obrázok nižšie), ktorá spúšťa iba sporné súbory.
V3	Na základe rozboru chýb: (1) **„špecialista“** – druhý model kaskády učený iba na sporných súboroch; (2) **doladenie prahu** na čerstvých neškodných programoch z apríla.
Overenie	Štatistická kontrola, či rozdiely nie sú náhodné, a prepočet iba na súboroch, ktorých spustenie v emulátore prebehlo bez chyby.

Ako funguje kaskáda B



Väčšinu súborov rozhodne rýchly statický model sám. Iba sporné súbory sa spúšťajú v emulátore – to je najdrahší krok.

3. Hlavné výsledky

Čím **vyšší** zachytený malvér a čím **menej** planých poplachov, tým lepšie. Riadky tučne sú najlepšie riešenia.

Prístup	Zachytený malvér	Plané poplachy na 10 000 neškodných	Zachytená nová rodina	Koľko súborov treba spustiť
Statický model (len obsah súboru)	**98,4 %**	**48**	**79 %**	**žiadny**
Dynamický model (len správanie)	65,7 %	198	51 %	všetky
Hybridný model (oboje naraz)	98,4 %	47	79 %	všetky
Komplexný hybrid (veľká neurónová sieť)	97,7 %	58	76 %	všetky
„Študent“ naučený od komplexného hybridu	97,0 %	83	76 %	žiadny
Kaskáda A (dvaja študenti, pri nezhode hybrid)	95,8 %	26	74 %	všetky
Kaskáda B so študentmi	95,9 %	34	73 %	11 %
Kaskáda B z modelov LightGBM	**98,3 %**	**39**	**78 %**	**22 %**

Zachytený malvér a plané poplachy: test na aprílových súboroch. Zachytená nová rodina: priemer zo 7 pokusov, v každom model jednu rodinu nikdy nevidel. Čas samotných modelov je zanedbateľný (zlomky tisíciny sekundy na súbor) – rozhoduje počet súborov, ktoré treba spustiť.

4. Ako dopadli tézy

Téza	Výsledok	Čo to znamená
1. Kombinácia (kaskáda) rozpozná nové druhy malvéru presnejšie a stabilnejšie	**nepotvrdená**	Najlepšie nové rodiny rozpozná samotný statický model (79 %). Žiadna kombinácia s údajmi o správaní to nezlepší – overili sme to viacerými spôsobmi. Príčinou sú údaje o správaní, nie spôsob kombinovania.

Téza	Výsledok	Čo to znamená
2. Kaskáda robí menej planých poplachov a pritom zachytí rovnako veľa malvéru	potvrdená	Kaskády z modelov LightGBM: 39 namiesto 48 planých poplachov na 10 000 programov a zachytený malvér klesne o menej ako 1 bod. Platí aj pri nových rodinách. Neplatí pre kaskády so „študentmi“ – tie zachytia o 2 – 4 body menej.
3. Destiláciou vznikne rýchlejší model s porovnateľnou presnosťou ako komplexný hybrid	čiastočne	Študent je rovnako presný ako veľká neurónová sieť, od ktorej sa učil, a 107-krát rýchlejší. Jednoduchý hybrid LightGBM je však ešte rýchlejší aj presnejší, takže študent nie je najlepšia voľba.
4. Viacstupňový systém zníži výpočtovú náročnosť	potvrdená	Kaskáda B spúšťa iba 22 % súborov a rozhoduje presne rovnako ako kaskáda, ktorá spúšťa všetky. Úsporu času vieme odhadnúť len zhora (spustenie trvá najviac 60 s), presne zmerať ju nemožno – databáza neobsahuje samotné programy.

5. Čo sme ďalej zistili

- **Hybridný model je rovnaký ako statický.** Údaje o správaní takmer nevyužije, lebo obsah súboru stačí.
- **Dynamický model s časom rýchlo starne:** na aprílových súboroch je výrazne horší ako na januárových. Navyše polovica aprílových spustení v emulátore skončila chybou (zrejme iná verzia emulátora).
- **Nové rodiny model „vidí“, ale hranicu má nastavenú príliš prísne.** Škodlivé súbory dostávajú vyššie skóre ako neškodné, no hranica nastavená v januári je v apríli prísnejšia, než sme chceli (0,5 % planých poplachov namiesto 1 %), a preto časť malvéru prepustí. **Doladenie hranice na asi 1 600 nových neškodných programoch** zvýši zachytenie novej rodiny z 79 % na 83 %. Na to netreba žiadny nový malvér. Pri asi 400 programoch to pomôže len niekedy.
- **Kde spustenie v emulátore prebehlo správne, údaje o správaní rozpoznávanie nových rodín dokonca zhoršujú** (hybrid o 4 body, špecialista o 3 body oproti samotnému statickému modelu).
- **Keylogger** (program sledujúci klávesnicu) je jediná rodina, ktorá je pre model naozaj nová – zachytí sa len 24 %.
- **„Študent“ sa učí dobre iba od zložitého učiteľa** (+2 body); od jednoduchého LightGBM sa nenaučí nič navyše.

6. Sú výsledky spoľahlivé, alebo je to náhoda?

Rozdiely medzi modelmi sú niekedy malé. Preto sme ich overili štatisticky: testovacie súbory sme 2 000-krát náhodne „premiešali“ (vybrali s opakovaním) a sledovali, či rozdiel zostane. **„Spoľahlivé“** znamená, že rozdiel nie je náhoda (s istotou 95 %). **„Rovnocenné“** znamená, že rozdiel je s istotou menší ako 1 bod. Kritériá sme si zapísali vopred.

Tvrdenie	Čísla	Výsledok kontroly
Kaskáda z LightGBM má menej planých poplachov ako statický model	39 vs. 48 na 10 000 (apríl); 36 vs. 47 (nové rodiny)	spoľahlivé
…a zachytí takmer rovnako veľa malvéru	rozdiel menší ako 1 bod (98,3 vs. 98,4 %)	spoľahlivé
Kaskáda B (spúšťa 22 % súborov) oproti hybridu, ktorý spúšťa všetky	rovnako veľa malvéru, 39 vs. 47 planých poplachov	spoľahlivé
Kaskády so študentmi rozpoznajú menej z novej rodiny	o 5 – 6 bodov menej ako statický model	spoľahlivé
Hybridný model = statický model; študent = učiteľ	rozdiely pod 1 bod	rovnocenné
Špecialista je lepší ako statický model	83,1 vs. 82,8 % pri rovnakom počte poplachov	nepreukázané
Doladenie hranice na nových neškodných programoch pomáha	asi 1 600 programov: 79 → 83 % asi 400 programov: v priemere 79 → 82 %	pri asi 1 600 áno

Neboli údaje o správaní len pokazené? V apríli skončila polovica spustení v emulátore chybou, takže by sa dalo namietať, že preto nepomáhajú. Prepočítali sme to preto iba na súboroch, kde spustenie prebehlo správne. Novú rodinu tam zachytí: statický model **92 %**, hybridný **88 %**, špecialista **89 %**. Údaje o správaní teda nepomáhajú ani vtedy, keď sú v poriadku.

7. Návrh, ako tézy preformulovať

Každá z nasledujúcich formulácií je už podložená výsledkami aj štatistickou kontrolou.

Navrhovaná téza	Na čom stojí	Stav
A. Viacstupňová kaskáda znižuje počet planých poplachov pri zachovaní miery odhalenia malvéru, a to aj pri nových rodinách malvéru. (rozšírenie tézy 2)	39 namiesto 48 planých poplachov na 10 000; zachytený malvér nižší o menej ako 1 bod	potvrdená
B. Spúšťanie iba sporných súborov dosiahne rovnakú kvalitu ako analýza všetkých súborov pri zlomku spustení. (spresnenie tézy 4)	22 % spustení; rovnaké rozhodnutia ako pri spúšťaní všetkých	potvrdená
C. Pri nových rodinách a s plynúcim časom je hlavnou príčinou chýb zle nastavená hranica, nie chýbajúca informácia. (nová téza)	doladenie hranice bez nového malvéru: 79 → 83 %	potvrdená
D. Údaje o správaní programu z emulácie nepomáhajú pri rozpoznávaní nových rodín malvéru. (náhrada tézy 1)	žiadna kombinácia nepridá viac ako 0,6 bodu; pri bezchybnom spustení dokonca zhoršujú	potvrdená
E. Destiláciou zo zložitého hybridného modelu vznikne rovnako presný, no mnohonásobne rýchlejší model. (zúženie tézy 3)	76,2 vs. 76,1 % novej rodiny; 107-krát rýchlejší	potvrdená

8. Na čo treba pamätať

- Všetko je na **jednej databáze** (7 rodín malvéru, iba 32-bitové programy pre Windows).
- Údaje o správaní pochádzajú z **emulátora** (napodobeniny Windows), nie zo skutočného spustenia v počítači.
- Čas spustenia v emulátore sa nedá zmerať (databáza neobsahuje samotné programy); 60 sekúnd je horná hranica.
- Krok V3 vznikol na základe rozboru výsledkov V2, preto nie je úplne nezávislým overením.
- Doladenie hranice používa neškodné programy z apríla, preto ho uvádzame ako samostatný scenár.

Podrobnosti a všetky čísla: dokumenty *docs/07, 10, 13, 17* v repozitári projektu.